

The AWS Account Security Hardening Runbook

Version: 1.0 (AWS Cloud Accelerator)

Section 1: Account Setup Checklist (New Accounts)

- ☐ Secure the Root Account: Enable Virtual MFA immediately.
- ☐ Lock away Root: Remove any root access keys and store the root password in a secure vault.
- ☐ Establish Billing Guardrails: Create an AWS Budget and CloudWatch billing alarm.
- ☐ Audit Trail: Enable AWS CloudTrail and route logs to an encrypted S3 bucket.
- ☐ Enforce Password Rules: Set a strict IAM password policy (minimum length, symbols, numbers, no reuse).

Section 2: IAM Best Practices (The 8 Rules)

1. **Least Privilege:** Never grant `AdministratorAccess` unless absolutely necessary.
2. **Zero Root Usage:** Never use the root account for daily operations.
3. **MFA Everywhere:** Enforce MFA for all console access using the `RequireMFA` policy.
4. **Roles over Users:** Use IAM Roles for applications (like an EC2 instance running backend code) instead of hardcoding access keys.
5. **Group-Based Access:** Never attach policies directly to a user. Place the user in a Group and attach the policy to the Group.
6. **Rotate Credentials:** Delete unused access keys and rotate active ones every 90 days.
7. **Use SCPs:** Apply Service Control Policies at the Organization level to prevent critical guardrails (like CloudTrail) from being disabled.
8. **Monitor the Perimeter:** Regularly check IAM Access Analyzer for unintended public access.

Section 3: Compromised Credential Incident Response

1. **Isolate:** Filter CloudTrail logs by the compromised `ResourceName` to identify the malicious actions and origin IP.
2. **Revoke:** Navigate to IAM, select the compromised user/role, delete all active Access Keys, and invalidate active console sessions.
3. **Quarantine:** Attach an explicit "Deny All" inline policy to the compromised identity.
4. **Remediate:** Investigate CloudTrail to reverse any infrastructure changes made by the attacker.

Section 4: Monthly Security Review

- ☐ Review the IAM Credential Report for old or unused passwords/keys.
- ☐ Check AWS Trusted Advisor for newly flagged security gaps.
- ☐ Verify CloudTrail is still actively logging to S3.
- ☐ Confirm no new IAM users were created without MFA enforcement.